

Data Privacy Compliance by Construction in Distributed Systems

GDPR Enforcement, Privacy by Design, and Consent-Based Data Handling

Chinmayi Prabhu Prasad Baramashetru

Department of Informatics
Faculty of Mathematics and Natural Sciences
University of Oslo



UNIVERSITY
OF OSLO

PhD Defense - 2025

Introduction

Hospitals Leaked Patient Data via Meta Pixel

- 1 Patient name
- 2 Date and time of appointment
- 3 Name of provider

```
{ "classList": "_Link+_actionable+_link+_readOnlyText+_InternalLink+m  
ain", "destination": "https://mychart.piedmont.org/PRD/app/communicat  
ion-center/conversation?id=ID REDACTED BY THE  
MARKUP", "id": "", "imageUrl": "/PRD/en-  
US/images/ProviderSilhouette.png", "innerText": "MyChart+Messaging+Us  
er\\nREDACTED BY THE MARKUP\\nAppointment+scheduled+from+MyChart\\  
nThere+is+a+message+in+this+conversation+that+has+not+yet+been+view  
ed.\\n 1 Appointment+For:+NAME REDACTED BY THE MARKUP+(ID REDACTED  
BY THE MARKUP)+Visit+Type:+NEW+PATIENT+(ID REDACTED BY THE MARKUP)+  
+ 2 MM/DD/YYYY+0:00+XX+00+mins.+ 3 NAME REDACTED BY THE  
MARKUP,+MD", "numChildButtons": 0, "tag": "a", "name": "" }
```

Source: mychart.piedmont.org, Mozilla Rally

33 of the top 100 US hospitals embedded Meta Pixel on patient portals

Hospitals Leaked Patient Data via Meta Pixel

- 1 Patient name
- 2 Date and time of appointment
- 3 Name of provider

```
{ "classList": "_Link+_actionable+_link+_readOnlyText+_InternalLink+m  
ain", "destination": "https://mychart.piedmont.org/PRD/app/communicat  
ion-center/conversation?id=ID REDACTED BY THE  
MARKUP", "id": "", "imageUrl": "/PRD/en-  
US/images/ProviderSilhouette.png", "innerText": "MyChart+Messaging+Us  
er\\nREDACTED BY THE MARKUP\\nAppointment+scheduled+from+MyChart\\  
nThere+is+a+message+in+this+conversation+that+has+not+yet+been+view  
ed.\\n 1 Appointment+For:+NAME REDACTED BY THE MARKUP+(ID REDACTED  
BY THE MARKUP)+Visit+Type:+NEW+PATIENT+(ID REDACTED BY THE MARKUP)+  
+ 2 MM/DD/YYYY+0:00+XX+00+mins.+ 3 NAME REDACTED BY THE  
MARKUP,+MD", "numChildButtons": 0, "tag": "a", "name": "" }
```

Source: mychart.piedmont.org, Mozilla Rally

33 of the top 100 US hospitals embedded Meta Pixel on patient portals

Names, appointments, and provider info leaked to Meta
without enforceable consent.

The Markup, 2022 ¹

¹<https://themarkup.org/pixel-hunt/2022/06/16/>

Why Do These Privacy Violations Happen?

Not because we lack laws:

- Over 150 jurisdictions now enforce data protection laws (e.g., GDPR, HIPAA)
- Organisations do claim **compliance** on paper

²<https://www.enforcementtracker.com/?insights>

Why Do These Privacy Violations Happen?

Not because we lack laws:

- Over 150 jurisdictions now enforce data protection laws (e.g., GDPR, HIPAA)
- Organisations do claim **compliance** on paper
- €5.6B in GDPR fines, 2,200+ cases (Enforcement Tracker, 2025)²
- GDPR enforces principles such as consent, purpose limitation, accountability, etc

²<https://www.enforcementtracker.com/?insights>

Why Do These Privacy Violations Happen?

Not because we lack laws:

- Over 150 jurisdictions now enforce data protection laws (e.g., GDPR, HIPAA)
- Organisations do claim **compliance** on paper
- €5.6B in GDPR fines, 2,200+ cases (Enforcement Tracker, 2025)²
- GDPR enforces principles such as consent, purpose limitation, accountability, etc

But systems don't know how to enforce them:

²<https://www.enforcementtracker.com/?insights>

Why Do These Privacy Violations Happen?

Not because we lack laws:

- Over 150 jurisdictions now enforce data protection laws (e.g., GDPR, HIPAA)
- Organisations do claim **compliance** on paper
- €5.6B in GDPR fines, 2,200+ cases (Enforcement Tracker, 2025)²
- GDPR enforces principles such as consent, purpose limitation, accountability, etc

But systems don't know how to enforce them:

- GDPR is prose; interpretive, high-level, sometimes ambiguous
- It defines **what** must happen, but not **how** to enforce it technically
- No canonical translation into architecture, code, or systems

²<https://www.enforcementtracker.com/?insights>

Why Do These Privacy Violations Happen?

Not because we lack laws:

- Over 150 jurisdictions now enforce data protection laws (e.g., GDPR, HIPAA)
- Organisations do claim **compliance** on paper
- €5.6B in GDPR fines, 2,200+ cases (Enforcement Tracker, 2025)²
- GDPR enforces principles such as consent, purpose limitation, accountability, etc

But systems don't know how to enforce them:

- GDPR is prose; interpretive, high-level, sometimes ambiguous
- It defines **what** must happen, but not **how** to enforce it technically
- No canonical translation into architecture, code, or systems

Result:

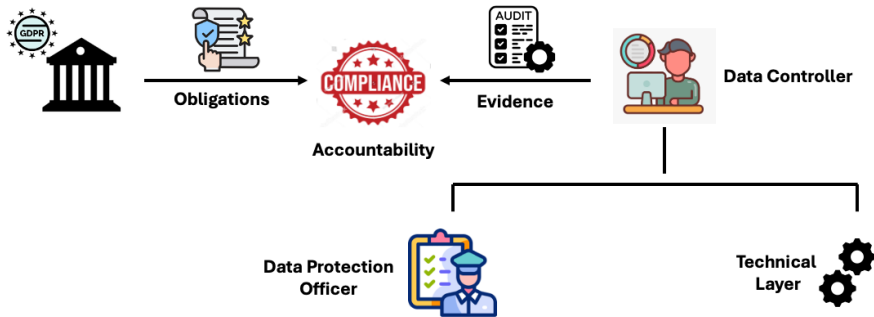
- Legal obligations are detached from system behaviour
- Enforcement relies on external audits and informal checklists

²<https://www.enforcementtracker.com/?insights>

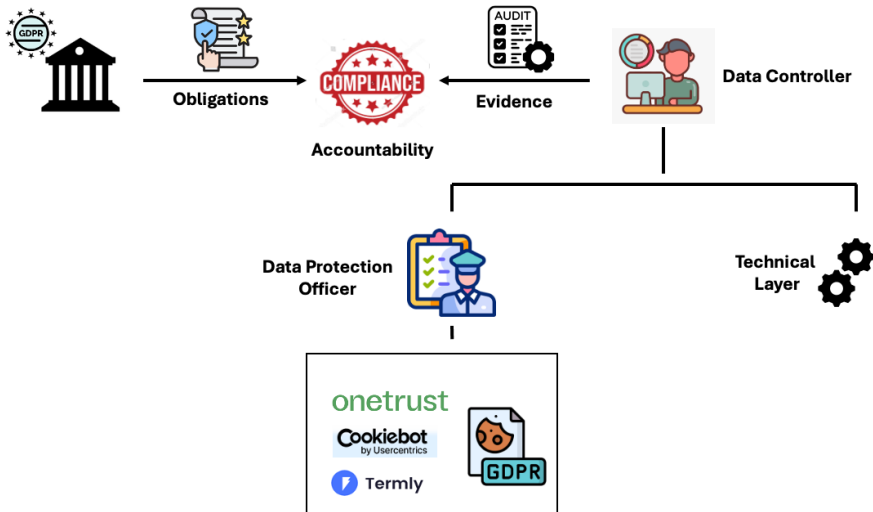
Compliance Today: Practices and Gaps



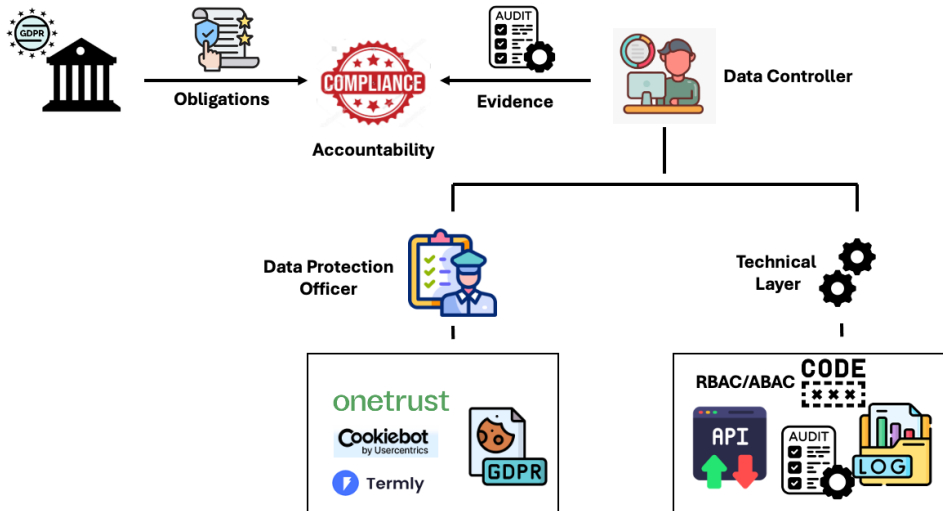
Compliance Today: Practices and Gaps



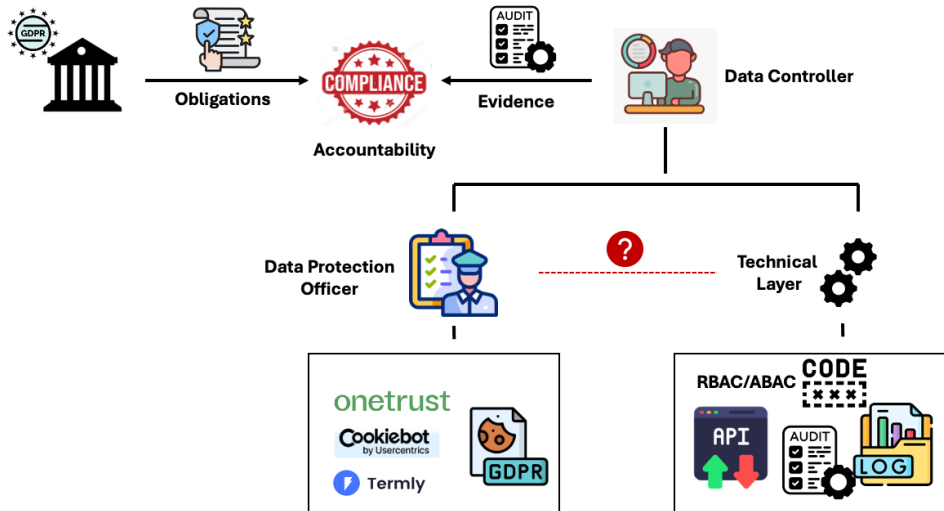
Compliance Today: Practices and Gaps



Compliance Today: Practices and Gaps



Compliance Today: Practices and Gaps



Language-Based Techniques for Data Privacy Compliance

GDPR: “Data protection by design and by default” (Art. 25)

Language-Based Techniques for Data Privacy Compliance

GDPR: “Data protection by design and by default” (Art. 25)

- Language-based techniques are extensively used in system specification.
- Semantics, type systems, and formal verification enforce correctness *by construction*.
- Non-Functional requirements - security via access control policies
- Calculus to reason about channels, ownership, and effects in distributed systems.

Language-Based Techniques for Data Privacy Compliance

GDPR: “Data protection by design and by default” (Art. 25)

- Language-based techniques are extensively used in system specification.
- Semantics, type systems, and formal verification enforce correctness *by construction*.
- Non-Functional requirements - security via access control policies
- Calculus to reason about channels, ownership, and effects in distributed systems.

Legal specification $\rightarrow$ formal specification

Language-based techniques enable compliance-by-construction

Research Goal

“To investigate how data privacy compliance can be achieved in distributed systems using formal language-based techniques.”

Research Goal

“To investigate how data privacy compliance can be achieved in distributed systems using formal language-based techniques.”

Techniques: Type theory, operational semantics, and policy logic

GDPR - Thesis Focus

GDPR Articles

Thesis Focus

- **Art. 5–7** — Principles: Consent, Purpose, Retention
- **Art. 12,15** — Data subject rights
- **Art. 24** — Controller and processor responsibilities
- **Art. 25** — Data protection by design and by default

This thesis targets an enforceable subset

Research Questions

Research Questions

RQ1: How to formalise data protection requirements into specifications?

Research Questions

RQ1: How to formalise data protection requirements into specifications?

RQ2: How can GDPR's core principles be integrated within a high-level object-oriented modelling language for distributed systems?

Research Questions

RQ1: How to formalise data protection requirements into specifications?

RQ2: How can GDPR's core principles be integrated within a high-level object-oriented modelling language for distributed systems?

RQ3: How can distributed systems enforce data privacy compliance according to users' consent?

- (a) How to define and enforce notions of data privacy compliance?
- (b) How can we ensure uninterrupted process execution in consent-driven systems by combining static and runtime checking?

Research Questions

RQ1: How to formalise data protection requirements into specifications?

RQ2: How can GDPR's core principles be integrated within a high-level object-oriented modelling language for distributed systems?

RQ3: How can distributed systems enforce data privacy compliance according to users' consent?

- (a) How to define and enforce notions of data privacy compliance?
- (b) How can we ensure uninterrupted process execution in consent-driven systems by combining static and runtime checking?

Research Papers

Research Papers

Paper I: A Policy Language to Capture Compliance of Data Protection Requirements

Paper II: Integrating Data Privacy Compliance in Active Object Languages

Paper III: Assuring GDPR Conformance through Language-Based Compliance

Paper IV: A Type System for Data Privacy Compliance in Active Object Languages

Data Privacy Compliance

Data Privacy Compliance

In all four papers, one principle persists:

Paper I: A Policy Language to Capture Compliance of Data Protection Requirements

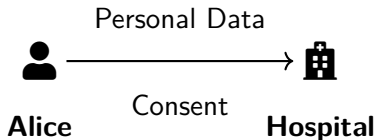
Paper II: Integrating Data Privacy Compliance in Active Object Languages

Paper III: Assuring GDPR Conformance through Language-Based Compliance

Paper IV: A Type System for Data Privacy Compliance in Active Object Languages

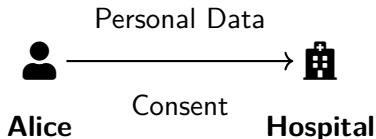
Compliance via Policy Specification Language

Scenario : Hospital Management System



Compliance via Policy Specification Language

Scenario : Hospital Management System



- Consent on the fly
- Uninformed consent - mechanically accept data controllers' policies
- Power imbalance between user and data controller

How to capture users' and data controllers' privacy preferences, under GDPR?

Compliance via Policy Specification Language

A formal specification language to capture privacy policies

Compliance via Policy Specification Language

A formal specification language to capture privacy policies

Policy Entry (PE):

$PE := (\text{Entity}, \text{Action}, \text{Purpose}, \text{Retention}, \text{Location})$

Compliance via Policy Specification Language

A formal specification language to capture privacy policies

Policy Entry (PE):

$PE := (Entity, Action, Purpose, Retention, Location)$

Each policy field is either:

- A finite set (Actions), or
- An expression interpreted over a taxonomy (Entity, Purpose, Location) or
- ISO timestamp (Retention)

Compliance via Policy Specification Language

A formal specification language to capture privacy policies

Policy Entry (PE):

$PE := (Entity, Action, Purpose, Retention, Location)$

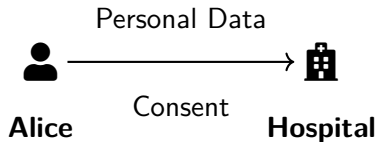
Each policy field is either:

- A finite set (Actions), or
- An expression interpreted over a taxonomy (Entity, Purpose, Location) or
- ISO timestamp (Retention)

Intuition:

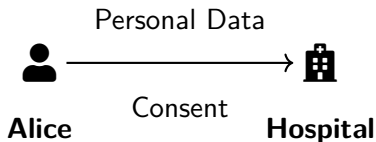
- Data controllers, processors and users can use the same language - unified language
- User policies are informed and prioritised
- Data controller and/or processor policies should respect user-specified policies.

Example 1 : Hospital Management System



- Alice gives consent via privacy policies

Example 1 : Hospital Management System

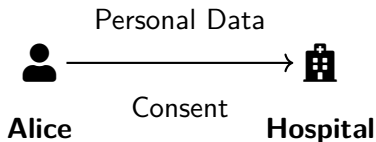


- Alice gives consent via privacy policies

Alice's Policy : $PE_{alice} = (\text{Hospital}, \text{use}, \text{treatment}, 01/01/2026, EU)$

Alice consents to *Hospital* to data *use* for *treatment* purpose until *01/01/2026* in *EU*.

Example 1 : Hospital Management System



- Alice gives consent via privacy policies

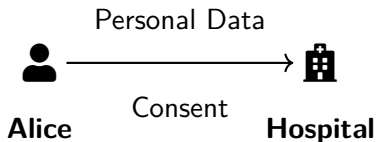
Alice's Policy : $PE_{alice} = (\text{Hospital}, \text{use}, \text{treatment}, 01/01/2026, EU)$

Alice consents to *Hospital* to data *use* for *treatment* purpose until *01/01/2026* in *EU*.

Hospital Policy:

$PE_{hosp} = (\text{Hospital}, \{\text{use}, \text{collect}, \text{store}\}, \{\text{treatment}, \text{research}\}, 10/10/2025, EU)$

Example 1 : Hospital Management System



- Alice gives consent via privacy policies

Alice's Policy : $PE_{alice} = (\text{Hospital}, \text{use}, \text{treatment}, 01/01/2026, EU)$

Alice consents to *Hospital* to data *use* for *treatment* purpose until *01/01/2026* in *EU*.

Hospital Policy:

$PE_{hosp} = (\text{Hospital}, \{\text{use}, \text{collect}, \text{store}\}, \{\text{treatment}, \text{research}\}, 10/10/2025, EU)$

Hospital policy allows more than the user's policy!

Compliance via Policy Specification Language

Compliance between user and data controller:

$$\overline{\text{PE}}_{DC} \sqsubseteq \overline{\text{PE}}_{DS}$$

In our hospital example,

$$\boxed{\overline{\text{PE}}_{Hosp} \sqsubseteq \overline{\text{PE}}_{Alice}}$$

- **Reduce** each policy by evaluating taxonomy expressions
- **Close** the system policy set under valid combinations (fixpoint)
- **Compare** using set containment across all fields

Compliance via Policy Specification Language

Compliance between user and data controller:

$$\overline{\text{PE}}_{DC} \sqsubseteq \overline{\text{PE}}_{DS}$$

In our hospital example,

$$\overline{\text{PE}}_{Hosp} \sqsubseteq \overline{\text{PE}}_{Alice}$$

- **Reduce** each policy by evaluating taxonomy expressions
- **Close** the system policy set under valid combinations (fixpoint)
- **Compare** using set containment across all fields

Result

- User preferences are captured and prioritised - reduces imbalance
- Compliance is a semantic relation over structured policy sets, among stakeholders

Compliance via Runtime Guarantees

From specification to execution

- We need a language where:
 - GDPR elements are language constructs
 - Consent aware syntax
 - Violations are prevented by semantics

Compliance via Runtime Guarantees

From specification to execution

- We need a language where:
 - GDPR elements are language constructs
 - Consent aware syntax
 - Violations are prevented by semantics

Key Idea: Compliance is a semantic invariant — enforced at each program step

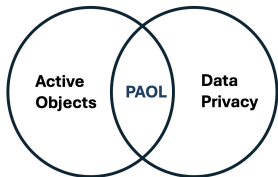
Compliance via Runtime Guarantees

From specification to execution

- We need a language where:
 - GDPR elements are language constructs
 - Consent aware syntax
 - Violations are prevented by semantics

Key Idea: Compliance is a semantic invariant — enforced at each program step

Privacy Aware Active Object Language



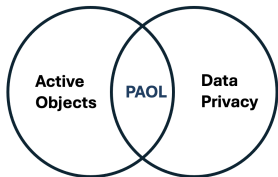
Compliance via Runtime Guarantees

From specification to execution

- We need a language where:
 - GDPR elements are language constructs
 - Consent aware syntax
 - Violations are prevented by semantics

Key Idea: Compliance is a semantic invariant — enforced at each program step

Privacy Aware Active Object Language



Syntax and Semantics

- Entity, purpose, consent, and personal data are first-class citizens
- Users can add/remove consent
- GDPR actions interpreted

Example 1.1 : Hospital Management System

Alice



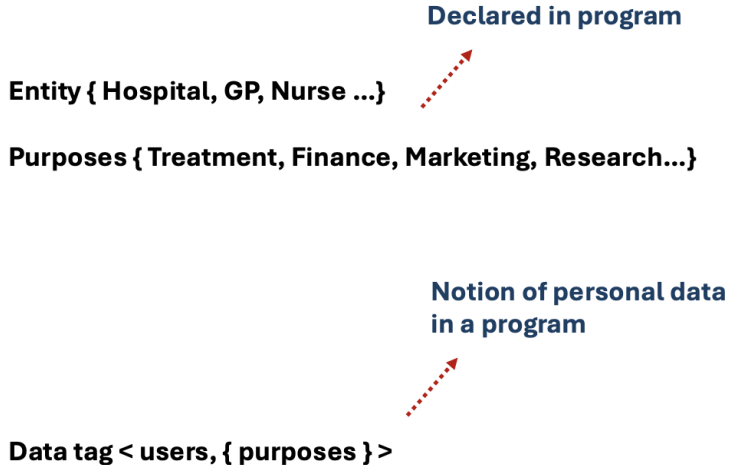
User

Hospital



Entity

Example 1.1 : Hospital Management System



Compliance via Runtime Guarantees

Transition System:

- Runtime configuration - multiset of runtime elements
- Each operational step is a transition:

$$\langle C \rangle \rightarrow \langle C' \rangle$$

- Applies private data handling auxiliary functions based on the rule

Example 1.2: Hospital Management System

Alice - User



Collects Consent



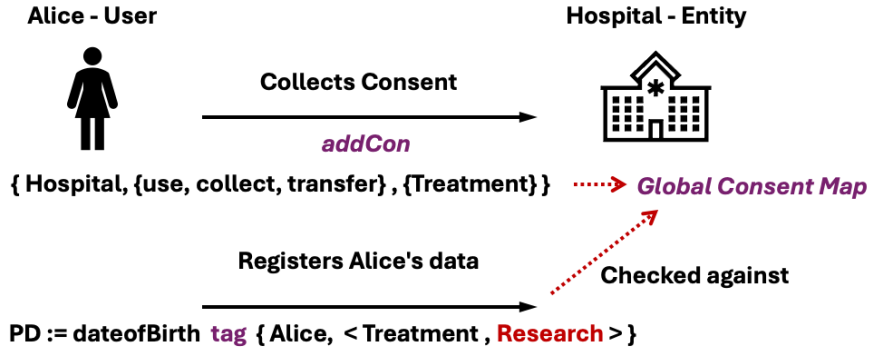
addCon

Hospital - Entity

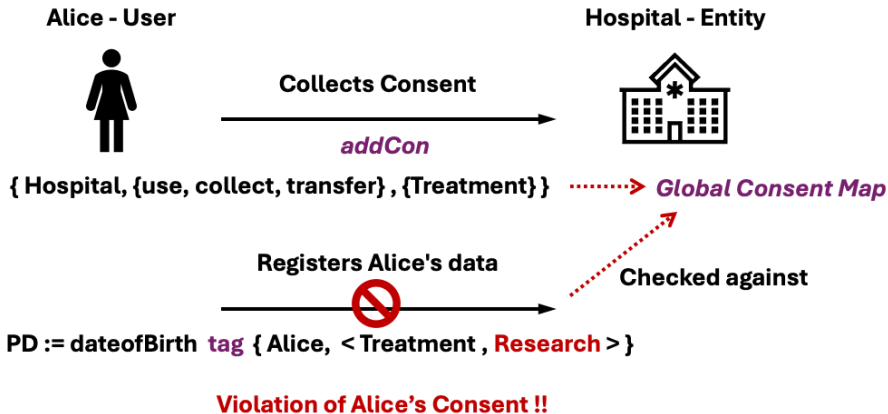


{ Hospital, {use, collect, transfer} , {Treatment} }

Example 1.2: Hospital Management System



Example 1.2: Hospital Management System



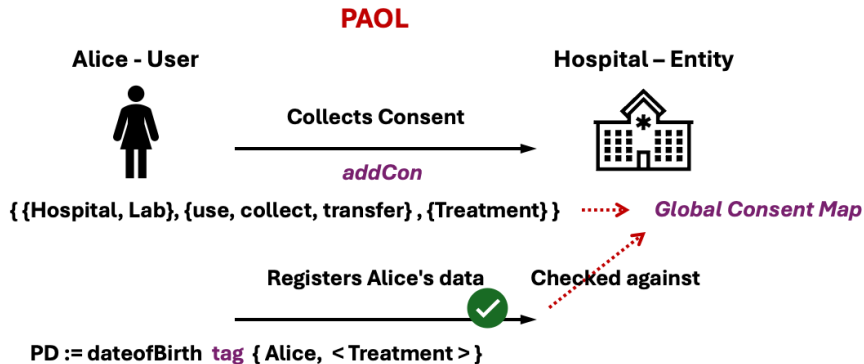
Compliance via Runtime Guarantees

All executions following our operational semantics are privacy compliant

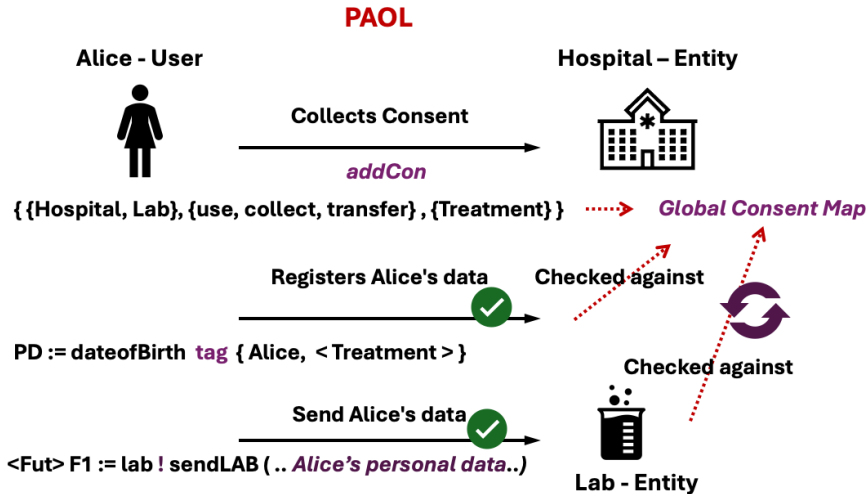
- Inductive proof over operational semantics
- Each reduction step holds the compliance invariant

$$\langle C \rangle \rightarrow \langle C' \rangle \quad \text{and} \quad \text{compliant}(C) \Rightarrow \text{compliant}(C')$$

Example 1.3: Hospital System (Non-Violating)



Example 1.3: Hospital System (Non-Violating)



Compliance via Static Guarantees

In PAOL's runtime semantics,

- Repeated runtime checks for consent validation
- Dynamic policy changes can interrupt operations

Compliance via Static Guarantees

In PAOL's runtime semantics,

- Repeated runtime checks for consent validation
- Dynamic policy changes can interrupt operations

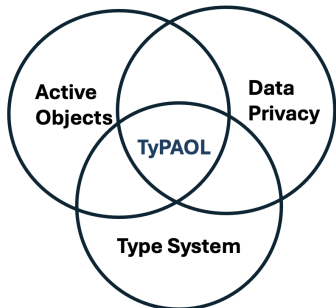
Can we shift some of these checks to compile time?

Compliance via Static Guarantees

In PAOL's runtime semantics,

- Repeated runtime checks for consent validation
- Dynamic policy changes can interrupt operations

Can we shift some of these checks to compile time?

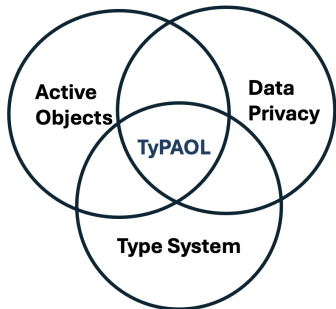


Compliance via Static Guarantees

In PAOL's runtime semantics,

- Repeated runtime checks for consent validation
- Dynamic policy changes can interrupt operations

Can we shift some of these checks to compile time?



TyPAOL Type System:

- Privacy annotation on types to represent personal and non-personal data.
- Tag annotation in data types
- Type environments to track consent and personal data

Compliance via Static Guarantees

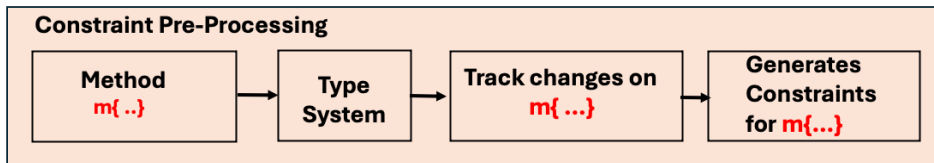
Typing Checking and Constraint Inference:

- Typing rules for expressions, statements, methods, and classes
- Statements handling personal data generate privacy constraints

Compliance via Static Guarantees

Typing Checking and Constraint Inference:

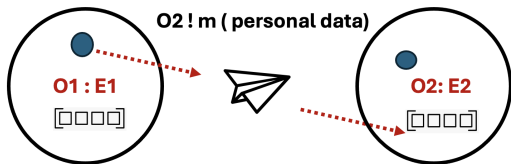
- Typing rules for expressions, statements, methods, and classes
- Statements handling personal data generate privacy constraints



- Method judgement checks if the body of a method is well-typed and gathers constraints
- Class judgement checks if all methods in a class are well-typed

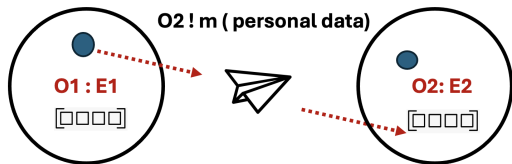
Compliance via Static Guarantees

Typed Operational Semantics:

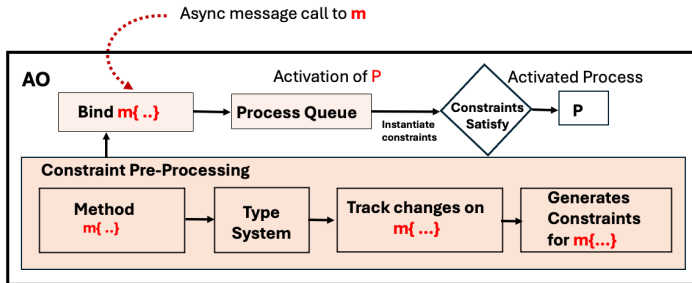


Compliance via Static Guarantees

Typed Operational Semantics:

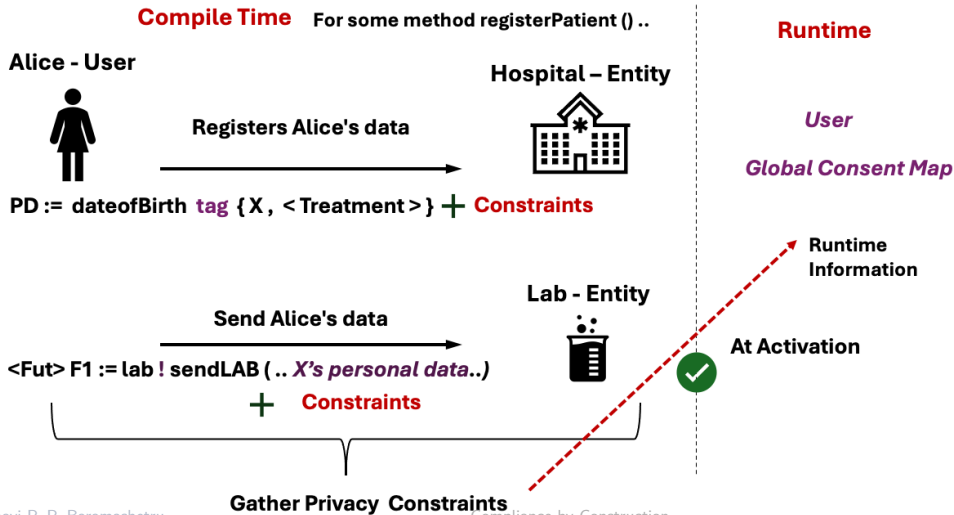


- Rule bind method and activation are attached with constraints
- Rule activate checks constraints gathered by the type system
- Checks against the runtime environment



Compliance via Static Guarantees

Example 1.4: Hospital Management System with constraints generation



Compliance via Static Guarantees

Soundness result of TyPAOL:

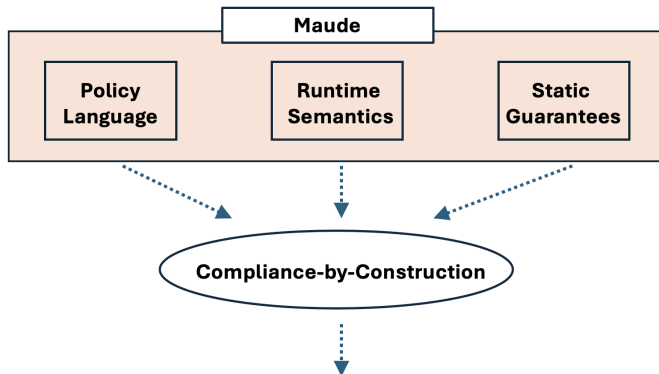
If a program is well typed, any non-idle object in a configuration is either waiting for a future or can make a reduction step

- Compliance predicates on personal data are always satisfied.

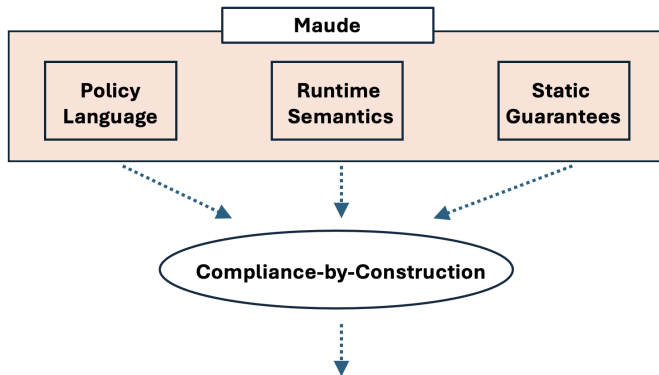
Guarantees:

- **Preservation:** If a program is compliant and takes a step, it remains compliant.
- **Progress:** A well-typed program can never get stuck for data privacy violations.

Research Contribution - Summary

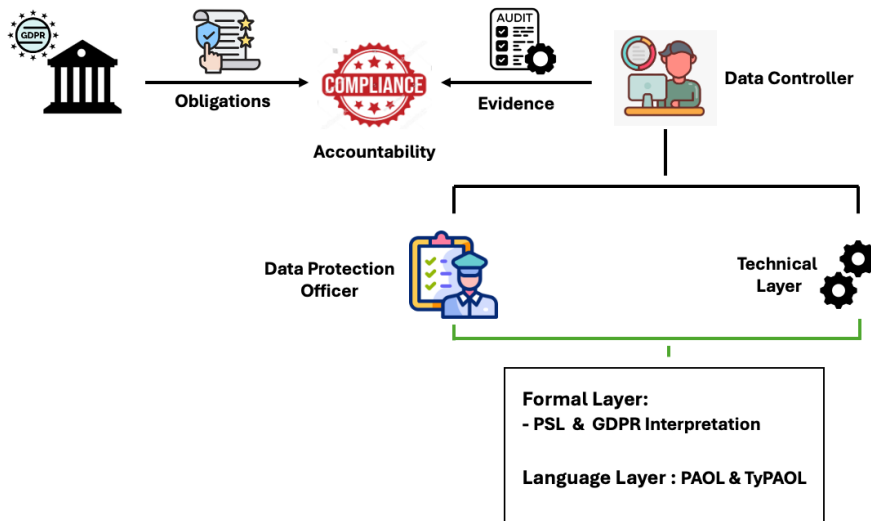


Research Contribution - Summary



To investigate how data privacy compliance can be achieved in distributed systems using formal language-based techniques.

Research Contribution - Summary



Future Work

- Provide more coverage for GDPR articles
- Policy specification language for negotiation protocol
- Extend language PAOL and TyPAOL with temporal properties (e.g, retention)
- Compositional compliance reasoning
- Extending type system to secure compilation targets

Thesis Summary and Main Result

Main Result

*Data privacy compliance can be enforced **by construction** in distributed systems through formal language-based techniques*

Contributions:

- A formal policy specification language for expressing GDPR obligations
- A privacy-aware modelling language based on active objects (PAOL)
- Operational semantics ensuring compliance at runtime
- A type system (TyPAOL) that statically guarantees compliance

From law to code — bridging specification, modelling, and execution.